TP1 — OSINT : l'empreinte d'une entreprise, du renseignement au phishing

> 4 h. Reconnaissance et ingénierie sociale, côté défense. MITRE ATT&CK : tactique **Reconnaissance** (TA0043).

Le contexte

En 2016, la banque belge **Crelan** a perdu **70 millions d'euros** dans une **fraude au CEO** : un escroc se fait passer pour un dirigeant et obtient un virement « urgent et confidentiel ». En 2026, le Centre pour la Cybersécurité Belgique classe toujours la **compromission de comptes, liée au phishing et à la fraude au CEO**, comme **menace n°1** en Belgique.

Ces attaques ne commencent pas par du code : elles commencent par de la **reconnaissance**. Qui est le patron ? Qui paie les factures ? Quel est le format des adresses e-mail ? Quand le patron est-il injoignable ? Tout cela se trouve souvent en **sources ouvertes** (OSINT). Et une fois le renseignement réuni, la dernière pièce est un **phishing kit** : une fausse page qui ressemble à un vrai portail.

Votre mission

ACME-BE, une PME de **Louvain-la-Neuve** (fictive), vous mandate pour un **audit d'exposition** : découvrir ce qu'un fraudeur peut apprendre sur elle **sans rien pirater**, mesurer comment ce renseignement se transforme en attaque, puis dire comment réduire cette exposition. Vous travaillez sur une **copie locale** de son site et de ses fichiers publics.

Livrable : une **fiche de renseignement** sourcée → le **profil de la cible** (son renseignement) → un **phishing kit** (la fausse page) → les **parades**.

> MITRE ATT&CK : tactique **Reconnaissance** (TA0043) — techniques *Search Victim-Owned Websites* (T1594), *Gather Victim Identity Information* (T1589), *Search Open Websites/Domains* (T1593), *Gather Victim Org Information* (T1591). La suite logique, *Phishing for Information* (T1598 : une fausse page qui récolte des identifiants), est abordée en **démonstration encadrée** (mission 6), jamais contre une vraie cible.

Règles du jeu

- **Cibles autorisées** : ACME-BE en local (`http://localhost:8080` et ses fichiers) et, en **lecture seule**, le domaine public `ephec.be`. La seule personne que vous recherchez, c'est **vous-même**.
- `ephec.be` **— ce qui est permis, précisément** : uniquement de l'**OSINT passif**, c'est-à-dire *lire* des sources déjà publiques *à propos* du domaine (whois, DNS publics, certificats, archives, moteurs). On ne se connecte pas au site pour le sonder, on ne scanne rien, on ne teste aucun identifiant : **on ne touche jamais les serveurs de l'EPHEC**. C'est légal et sans risque — et au passage, vous apprendrez des choses sur votre propre école.
- **Mission 6 (phishing kit)** : la fausse page se fabrique et se teste **dans votre VM uniquement**, sur la copie locale d'ACME, avec des identifiants bidons. **Aucun lien envoyé**, jamais un vrai site.
- **10 flags** `ACME{...}` dans la cible locale : c'est le **jeu** (ils prouvent que vous avez *trouvé*, pas que vous avez *compris*). Le **but**, lui, ce sont les **données** que vous récoltez autour de chaque flag : noms, rôles, format d'e-mail, absences, portails… Assemblées, elles forment le **profil de la cible** (mission 5), qui arme ensuite le **phishing kit** (mission 6). Le noté, c'est la **fiche sourcée**, pas les flags. *(La numérotation des flags suit l'ordre probable de découverte, pas l'ordre des missions — pas d'inquiétude si une mission saute des numéros.)*
- **Compétition** (pour la gloire, pas pour la note) : premier ou première sur un flag ? **Montrez-moi l'écran** ou **envoyez-le-moi par Teams** (sans le crier). Votre nom va au tableau.
- **STOP** : des arrêts rythment la séance — on lâche le clavier, on met en commun, on repart.
- **IA** : tuteur oui (expliquer une commande, une sortie), presse-bouton non — vous devez pouvoir **tout expliquer à l'oral**. Jamais de données personnelles dans une IA tierce.

Mise en bouche — Vous, vu d'Internet (15 min)

Avant ACME, retournez les outils **vers vous-même**. Pendant que votre VM démarre, ouvrez un navigateur. **Sur vous-même uniquement**, en lecture seule.

1. **Se chercher** : `"Prénom Nom"` (avec les guillemets) dans un moteur, puis votre e-mail entre guillemets. Que sort-il en premier ?
2. **Fuites** : https://haveibeenpwned.com — votre e-mail a-t-il fuité, et dans quelles brèches ?
3. **Un e-mail, combien de comptes ?** : https://epieos.com — entrez **votre** adresse : quels services (compte Google, etc.) y sont rattachés ?
4. *(facultatif)* **Reconnaissance faciale** : https://pimeyes.com — seulement si vous le voulez, et **votre** visage uniquement, jamais celui d'un autre. On en discutera.
5. **Votre premier outil Kali — à dénicher vous-même.** Dès que la VM est prête, ouvrez le **menu des applications de Kali** et explorez ses catégories : c'est votre nouvel outil de travail, apprenez à vous y repérer. Trouvez-y un programme **en ligne de commande** qui recherche un **pseudo** sur des dizaines de sites, et lancez-le sur **votre** pseudo. *(Pour trouver le bon outil : l'annuaire **OSINT Framework** — osintframework.com — classe les outils par objectif, catégorie «*

Username ». Et votre prof vous indiquera la catégorie du menu Kali si vous séchez.) Combien de comptes oubliés retrouvez-vous ? Réutiliser le même pseudo partout, quel risque ?

Puis on se tourne vers une **entreprise**.

Mission 0 — Lancer la cible ACME (15 min)

Votre VM tourne déjà (mise en bouche). On passe à ACME :

1. Récupérez les ressources du TP : `git clone https://github.com/xavierdubruille/secu_tp.git` (ou `git pull` si vous l'avez déjà). La cible est dans `secu_tp/TP1-osint/cible`.
2. **Docker n'est pas encore installé ?** (fréquent sur une Kali fraîche) Installez-le **une fois** :

   ```
   sudo apt update
   sudo apt install -y docker.io docker-compose
   sudo systemctl enable --now docker
   sudo usermod -aG docker "$USER"    # puis déconnexion/reconnexion (ou : newgrp
       docker)
   ```

   Un script tout prêt fait la même chose : `bash secu_tp/TP1-osint/cible/install-docker.sh`.
3. Lancez la cible : `cd secu_tp/TP1-osint/cible && docker compose up -d && docker ps`. *(Selon la version installée, la commande est `docker compose` — avec espace — **ou** `docker-compose` — avec tiret. Les deux font la même chose.)*
4. Ouvrez `http://localhost:8080`.
5. Dans votre **dépôt Git perso** : créez `tp1/fiche.md` (modèle en fin d'énoncé), commit, push.

Point de contrôle : vous voyez la vitrine d'ACME **et** votre dépôt contient `tp1/fiche.md`.

Mission 1 — La vitrine (25 min) · flags 1-2

Commencez comme un fraudeur : par ce qu'ACME montre **volontairement**.

À trouver (notez tout dans la fiche, avec la source) :

- les **personnes** et leurs **rôles** ; les **adresses e-mail** et leur **format** ;
- ce qui est visible **sans être destiné à l'être** (2 flags).

Question : parmi vos trouvailles, lesquelles sont publiées **volontairement**, lesquelles sont des **fuites** ? Pourquoi la différence compte-t-elle ?

Pour le profil de la cible (mission 5) : repérez dès maintenant **qui dirige**, **qui paie les factures**, le **format des e-mails** et **quand le patron est absent**. Le profil se remplit mission après mission.

Mission 2 — Les fichiers parlent (40 min) · flags 3, 4, 5, 9

ACME publie des photos et des documents. Un fichier contient **plus** que ce qu'il montre.

À trouver :

- **Où** se trouve le siège d'ACME ? (une adresse, pas juste des chiffres)
- **Qui** a produit chaque document ? Avec quel outil ? Quand ?
- Une personne **travaille chez ACME** mais n'apparaît **pas** sur le site : qui ?
- Regardez **aussi** les photos elles-mêmes, pas seulement leurs métadonnées.

Questions : pourquoi une photo de téléphone embarque-t-elle une position ? Qu'est-ce qu'un fraudeur peut faire d'un **nom de compte Windows** ?

Pour le profil de la cible : chaque **auteur** de document et chaque **détail interne** (outil, chemin, projet en cours) rendra un faux e-mail crédible. Ajoutez-les au profil.

> **STOP 1 — mise en commun** (15 min) puis **pause** (10 min).

Mission 3 — Les fichiers qui mentent (25 min) · flags 6, 7, 8

Trois fichiers ne sont pas ce qu'ils ont l'air d'être.

- Une **image** contient autre chose qu'une image.
- Une **chaîne de caractères** a l'air chiffrée. L'est-elle vraiment ?
- Un **carré noir et blanc** attend d'être lu.

> **Vos outils ici** (en **ligne de commande** — ils ne sont pas dans les menus de Kali) : `file` (le *vrai* type d'un fichier, par son contenu), `binwalk` puis `unzip` (repérer et extraire un fichier caché dans un autre), `base64 -d` (décoder du base64), `zbarimg` **ou votre téléphone** (lire un QR code). `strings` peut dépanner.

Questions : quelle différence entre **encoder** et **chiffrer** ? Pourquoi ne jamais se fier à l'**extension** d'un fichier ?

Mission 4 — L'entreprise vue des sources publiques en ligne (20 min)

La même démarche que sur ACME, mais à l'échelle d'Internet, **en lisant seulement ce qui est public** : sur `ephec.be`, on ne touche à rien (voir les règles du jeu).

> **Le réflexe « quel outil pour quoi ? »** : gardez **OSINT Framework** (osintframework.com) ouvert. C'est un annuaire d'outils OSINT classés **par objectif** (domaine, e-mail, sous-domaine, archive, réseaux sociaux…). Bloqué sur « par où chercher X ? », il vous oriente — c'est l'outil de votre autonomie.

A. Le nom de domaine parle — sur `ephec.be`

```
whois ephec.be                  # qui a enregistré le domaine, quand, chez quel
        registrar
dig ephec.be MX +short          # chez qui part le courrier (Google ? Microsoft ?
        interne ?)
dig ephec.be TXT +short         # SPF, vérifications de services tiers, indices d'outils
        utilisés
```

Question : rien qu'avec l'enregistrement MX et les TXT, que devinez-vous de l'infrastructure de messagerie de l'entreprise ? En quoi est-ce utile à un fraudeur ?

> **Si `whois` ou `dig` ne répondent pas** depuis la VM (leurs ports — 43 et 53 — sont souvent **filtrés par le réseau de l'école**), passez par un service web équivalent, qui lit les mêmes registres publics : whois DNS Belgium (https://www.dnsbelgium.be/fr/whois) pour un `.be`, ou who.is ; pour le DNS, https://mxtoolbox.com (MX, TXT/SPF) ou https://dnschecker.org. Même information, autre chemin.

B. Les sous-domaines, via les certificats publics

- Ouvrez https://crt.sh/?q=ephec.be (**Certificate Transparency** : tout certificat HTTPS émis y est publié). Quels sous-domaines apparaissent ? Lesquels intéresseraient un attaquant (`vpn`, `webmail`, `admin`, `dev`, `old`, `test`) ?

C. Le passé du site : Wayback Machine

- Sur https://web.archive.org/, entrez `ephec.be` et comparez une version ancienne à aujourd'hui (organigramme, numéro direct, page « équipe » plus bavarde, document retiré). Pourquoi une info **retirée** reste-t-elle trouvable des années après ?

D. Les « Google dorks » : cibler la recherche

Les **opérateurs avancés** forcent un moteur à montrer du précis. Sur `ephec.be` :

```
site:ephec.be filetype:pdf              # documents publics -> puis exiftool dessus
(mission 2 !)
site:ephec.be intitle:"index of"        # répertoires laissés ouverts
site:ephec.be inurl:login               # portails de connexion (inurl:webmail,
inurl:vpn)
"@ephec.be"                             # confirmer le format des adresses e-mail
```

Quel dork rapporte le plus à un fraudeur ? Lequel recoupe crt.sh ?

> **Des dorks prêts à l'emploi** : la *Google Hacking Database* (https://www.exploit-db.com/google-hacking-database) en recense des centaines, classés par catégorie (fichiers sensibles, portails, messages d'erreur…). Parcourez-la avec l'œil d'un **testeur d'intrusion** : lesquels tenteriez-vous en premier sur une entreprise, et pourquoi ?

E. Tout ça, automatiquement : SpiderFoot *(montré en démo ; à retester chez vous en option)*

`spiderfoot` agrège whois, DNS, crt.sh, moteurs… et **dessine le graphe** des liens trouvés (domaine → sous-domaines → e-mails → personnes). Lancez-le en **mode « Passive » uniquement** — les autres modes (*Footprint / Investigate / All*) **sondent réellement** la cible, ce qui serait de la reconnaissance **active** (hors cadre ici) :

```
spiderfoot -l 127.0.0.1:5001     # puis, dans le navigateur : New Scan -> type de scan
       « Passive »
```

> **RGPD — la limite, ici** : sur un vrai domaine, on cherche l'**infrastructure, les documents, le format des adresses** — **pas** les personnes. L'énumération d'employés ne se fait **que sur ACME** (fictif). On ne fiche aucun employé réel de l'EPHEC.

> **STOP 2 — mise en commun** (10 min).

Mission 5 — Le profil de la cible (20 min) · synthèse

Mettez-vous **à la place du fraudeur**. Le « profil de la cible », c'est son **renseignement** : tout ce qu'il a appris sur ACME (le *phishing kit*, la fausse page, viendra en mission 6). Avec **uniquement** ce que vous avez trouvé, complétez dans votre fiche (chaque case **sourcée** : fichier, page, commande) :

Question du fraudeur	Votre réponse	Source
Qui dois-je convaincre de faire un virement ?		
Au **nom de qui** vais-je écrire ?		
Quelle **adresse e-mail** vais-je imiter ? (déduite, pas publiée)		
Quand frapper ?		
Quels **détails internes** rendront mon message crédible ? (au moins 2)		
Par **quel portail** l'employé se connecte-t-il ?		

Question : quel est le **maillon** de cette chaîne qu'ACME pourrait casser le plus facilement ?

Mission 6 — Le phishing kit : SET en labo isolé (25 min) · flag 10

Vous avez tout : la cible, le prétexte, et le **portail webmail** par lequel le personnel se connecte. La dernière pièce d'une fraude, c'est un **phishing kit** (kit d'hameçonnage) : une **fausse page** identique au vrai portail, qui **capture** les identifiants saisis. On en fabrique un **une seule fois**, **dans votre VM**, sur la **copie locale d'ACME**, pour comprendre pourquoi ça marche — puis on verra comment s'en protéger.

Cadre, non négociable : tout reste **dans votre VM**. On clone **uniquement** la page locale d'ACME (`http://localhost:8080/webmail.html`). On tape **des identifiants bidons** (`test / test123`). On n'envoie **aucun lien** à personne, on ne pointe **jamais** vers un vrai site. (Cadre éthique du cours 1, accepté sur Moodle.)

1. Dans votre VM, lancez `setoolkit`.
2. `1) Social-Engineering Attacks` → `2) Website Attack Vectors` → `3) Credential Harvester Attack Method` → `2) Site Cloner`.
3. Adresse d'écoute : votre IP locale (`127.0.0.1`). URL à cloner : `http://localhost:8080/webmail.html`.
4. Ouvrez la page clonée **dans votre propre navigateur** (l'adresse d'écoute de SET). Comparez-la à l'originale : identique ?
5. Tapez `test / test123` et validez. Regardez la **console SET** : vos identifiants bidons s'y affichent.
6. Regardez la **barre d'adresse** de la page clonée : qu'est-ce qui ne colle pas ?

> **Si, après avoir validé, la page retombe sur SET (ou une page blanche) au lieu du portail ACME** : c'est le comportement **par défaut** de SET. Pour que la fausse page renvoie la « victime » vers le vrai portail local après la capture (le détail qui rend une vraie attaque invisible), éditez la config **avant** de lancer l'outil — `/etc/setoolkit/set.config` (parfois `~/.set/set.config`) :
>
> ```
> AUTO_DETECT=OFF                                    # pour saisir toi-même l'IP
> d'écoute (127.0.0.1)
> HARVESTER_REDIRECT=ON
> HARVESTER_URL=http://localhost:8080/webmail.html  # le vrai portail ACME local
> ```

Questions : (a) quel **seul détail** dans le navigateur trahissait la fausse page ? (b) pourquoi la **double authentification (MFA)** réduit-elle fortement l'intérêt de cette attaque ? (c) pourquoi un **gestionnaire de mots de passe** vous protège-t-il presque automatiquement ?

> **STOP 3** (5 min) : « qu'est-ce qui vous a surpris : sur ACME, ou sur **vous** ? »

Mission 7 (optionnelle) — Se défendre

> **Optionnelle.** Vous avez déjà beaucoup manipulé `exiftool` : la manipulation `mat2` ci-dessous peut se faire **chez vous** (ou être vue en **démo**). En revanche, les **3 recommandations** restent **attendues dans la fiche** (c'est le cœur du rendu).

On apprend l'attaque **pour** défendre.

1. *(optionnel / démo)* Copiez `siege.jpg` , nettoyez-le avec `mat2` , puis comparez **avant / après** avec `exiftool` .
2. Dans votre fiche : **3 recommandations concrètes** pour ACME (une par type de fuite), **dont une contre le phishing** de la mission 6.
3. **Une action** que vous allez faire **pour vous** (pseudo, photos, comptes oubliés, MFA).

Votre rendu

Dans le **devoir Moodle du TP1** (et dans votre dépôt Git, `tp1/`) :

1. Votre **fiche** : trouvailles **sourcées** + le **profil de la cible** + **3 recommandations** (dont une anti-phishing).
2. **Une capture** d'un résultat marquant + **la commande** qui l'a produit + **une phrase** d'explication. *(Ça peut prendre une autre forme — quelques captures d'écran, par exemple : vous devez juste montrer que vous avez **fait** le TP.)*
3. **(BONUS, maison)** une **room OSINT** en ligne : **TryHackMe « OhSINT »** (gratuite, ~1 h). Rendez le **drapeau final** + **2-3 captures** montrant *comment* vous avez remonté la piste. Alternative sans compte : un défi **Gralhix** (gralhix.com).

Noté : le barème précis est sur **Moodle**. L'essentiel noté, c'est la **fiche** (travail de séance) ; la room OSINT maison compte en **bonus**. Pas fini en séance ? Le devoir reste ouvert : terminez chez vous.

Modèle de fiche (`tp1/fiche.md`)

```
# TP1 — Fiche de renseignement ACME-BE        (nom, prénom)

## Trouvailles
| # | Information | Source (page / fichier) | Méthode (outil, commande) | Fuite
        volontaire ? |
|---|---|---|---|---|
| 1 |   |   |   |   |

## Flags
| # | Flag | Où | Comment |
|---|---|---|---|

## Le profil de la cible
(qui viser, au nom de qui, quelle adresse, quand, quels détails, quel portail — chaque
        ligne sourcée)

## Le phishing kit (mission 6)
(ce qui trahissait le faux portail ; pourquoi le MFA et le gestionnaire de mots de
        passe protègent)

## Recommandations pour ACME (3, dont une anti-phishing)
## Une action pour moi
```

Boîte à outils (préinstallée sur la VM Kali)

Outil	Pour quoi	Où
navigateur (`Ctrl+U`)	code source, fichiers servis	local
`exiftool`	métadonnées (auteur, logiciel, dates, GPS)	local
`file` , `strings` , `binwalk`	vrai type, chaînes lisibles, fichiers imbriqués	local
`base64` , `zbarimg`	décoder du base64, lire un QR code	local
`mat2`	**nettoyer** les métadonnées (défense)	local
`whois` , `dig`	enregistrement de domaine, DNS publics (MX, TXT/SPF)	en ligne (lecture)
Google dorks (`site:` , `filetype:` , `inurl:` , `intitle:`)	cibler ce qu'un moteur sait déjà	en ligne (lecture)
OSINT Framework (web)	**annuaire d'outils OSINT classés par objectif** (le réflexe « quel outil pour X ? »)	en ligne (lecture)
crt.sh (web)	sous-domaines via Certificate Transparency	en ligne (lecture)
Wayback Machine (web)	anciennes versions d'un site public	en ligne (lecture)
`sherlock`	présence d'un pseudo sur des centaines de sites	en ligne (lecture)
Have I Been Pwned (web)	dans quelles fuites votre e-mail apparaît (échauffement, **sur soi**)	en ligne (lecture)
PimEyes (web)	reconnaissance faciale — **facultatif, sur votre propre image** (échauffement)	en ligne (lecture)
`theHarvester` , `amass`	e-mails et sous-domaines (sources publiques agrégées)	en ligne (maison)
`spiderfoot`	automatisation OSINT + graphe (démo)	en ligne (démo)
Shodan (web)	machines et services exposés	en ligne (maison)

Outil	Pour quoi	Où
`setoolkit` (SET)	**clonage d'un portail** pour comprendre le phishing (labo isolé)	VM isolée

À retenir pour l'examen

À savoir **expliquer**, sur un cas qu'on vous donne :

1. Reconnaissance **passive** (lire des sources publiques, comme un visiteur) ou **active** (interroger directement les systèmes de la cible : TP2).
2. Ce qu'un fichier révèle sans qu'on le voie (**métadonnées** : auteur, logiciel, dates, GPS) et comment le nettoyer.
3. **Encoder n'est pas chiffrer** ; l'extension ne prouve pas le type d'un fichier.
4. Ce que des **sources publiques en ligne** révèlent sur une organisation sans la toucher (DNS et enregistrement de domaine, certificats via crt.sh, Wayback Machine).
5. Comment des informations anodines s'assemblent en **profil de la cible** (le renseignement), puis en **phishing kit** (la fausse page) pour une **fraude au CEO** ; et pourquoi « faire attention » ne suffit pas (MFA, vérifier l'URL, double validation des virements).
6. Pour chaque fuite, **une parade** ; et la limite : pas de personne réelle (RGPD).

- **Les outils** : savoir à quoi sert chacun (exiftool, mat2, file, base64, whois, dig, crt.sh, Wayback, sherlock, SET), pas leurs options.
- **Pas à apprendre par cœur** : les flags, les détails d'ACME, le montant de la fraude Crelan, la syntaxe exacte des commandes, les menus de SET.
- Toute la matière, séance par séance : page « Matière d'examen » sur Moodle.

Pour aller plus loin

- **OSINT Framework** (osintframework.com) — à garder sous la main : l'annuaire d'outils par objectif.
- **Google Hacking Database** (exploit-db.com/google-hacking-database) — des centaines de dorks prêts à l'emploi, par catégorie.
- **Root-Me** (notre compétition de l'année) — catégorie *Stéganographie* / *Forensic* pour la suite.
- Cas réels : TV5Monde 2015 (mots de passe visibles dans un reportage TV) ; fuite **Canvas** (mai 2026).